

PRODUCT SPECIFICATION DOCUMENT (PRD)

Project Name: Portfolio Dashboard — Indian Mutual-Fund CAS Analyzer

Date: 2026-07-13 (originally 2026-07-04; comprehensively revised after the 2026-07-03 architecture review's C/N/U/A/S/T/D workstreams and the 2026-07-12 comprehensive review's Theme A–E follow-ups, tracked as `tasks.md` R1–R23, all landed)

Author / Product Owner: Amay Narayan (Product Owner & Lead Maintainer)

Version: 1.1.0

Status: As-built specification of the shipped `app/` implementation. Nearly everything that was "planned"/"target" in v1.0.0 is now built and verified; the few remaining forward-looking items are explicitly marked **Deferred** with the reason, not "planned."

How this document relates to the others

- `product_spec.md` (**this file**) — the single source of truth for *what the product is and does today*, plus the quality bar it must meet.
- `plan.md` — the historical build blueprint and the 2026-07-03 architectural review (§0 locked decisions). Retained for rationale; not a description of current behaviour.
- `tasks.md` — the forward-looking, numbered task tracker and progress checklist (the source of truth for *status and what's next*).
- `docs/ARCHITECTURE.md` • `docs/DECISIONS.md` • `docs/TESTING.md` — module map, decision/bug-fix log with invariants, and the test strategy.

Table of Contents

1. Executive Summary & Objectives
2. User Personas & Core Journeys
3. Functional Requirements (Scope & Features)
4. Non-Functional Requirements (NFRs)
5. Technical Architecture & Data Strategy
6. UI/UX & Design System Guidelines
7. Release Plan, Milestones & Risk Management
8. Guardrails — What This Product Must NOT Do
9. Glossary

1. Executive Summary & Objectives

1.1 Project Overview

Portfolio Dashboard is a **privacy-first, browser-based web application** that turns an Indian **CAMS / Kfintech Consolidated Account Statement (CAS)** into a complete mutual-fund portfolio analysis — returns (XIRR / CAGR), capital-gains split (STCG / LTCG), look-through asset and geographic allocation, live-NAV revaluation, a benchmarked comparison against the Nifty 50, a visual chart gallery, an automatic data-integrity check, and age-tailored educational commentary.

Its defining architectural property is that **the user's financial statement never leaves their device**. Parsing, computation, and rendering all happen client-side in the browser. The network is touched **only** to fetch public NAV (Net Asset Value) prices, and those requests carry a scheme name or ISIN — never a PAN, folio number, holding, or amount.

The core value proposition: **a trustworthy, zero-friction "upload and understand" experience** — a retail investor drops their consolidated statement and, within seconds, sees a professional-grade read of their portfolio that a spreadsheet cannot produce and that a commercial service would require them to surrender their data to obtain.

Since v1.0.0, the product has moved from a trustworthy **mirror** of the statement toward **genuine empowerment** — a comprehensive review (2026-07-12) against this same objective found the app computed everything needed for actionable guidance (per-lot gains, expense ratios, per-fund benchmarks) but surfaced almost none of it as "here's what to look at." Every jargon-dense number on the dashboard now carries a point-of-use explainer; the app proactively flags a small number of specific, data-derived observations (a high-expense fund, a benchmark-lagging fund, a concentration risk) rather than leaving the investor to notice them unaided; and the age-tailored commentary projects an actual retirement corpus rather than stopping at a qualitative risk-band verdict.

1.2 Problem Statement

Indian retail mutual-fund investors face a specific, well-defined set of pain points:

#	Pain Point	Consequence Today
P1	The CAS PDF is dense, tabular, and unfriendly — dozens of schemes, hundreds of transactions, no computed returns.	Investors cannot easily answer "how am I actually doing?"
P2	Accurate money-weighted return (XIRR) across many contribution dates is effectively impossible by hand or in a naive spreadsheet.	Investors rely on the misleading value ÷ cost ratio, which understates return for portfolios funded over time.
P3	Capital-gains (STCG vs LTCG, per-lot, with the 12-month equity / 24-month debt threshold) are tedious and error-prone to compute manually.	Tax planning is guesswork.
P4	Commercial portfolio analyzers require uploading the full statement (PAN, folios, holdings) to a third-party server .	A genuine privacy and data-security risk that deters the privacy-conscious.

#	Pain Point	Consequence Today
P5	There is no easy, honest benchmark comparison ("did I beat a simple Nifty 50 index fund?") tied to the investor's own cash-flow timing.	Investors cannot judge whether active choices added value.
P6	Generic robo-advice ignores the investor's horizon (years to retirement).	One-size-fits-all guidance that doesn't fit.

1.3 Target Audience

Primary users

- **The self-directed Indian retail investor** — holds mutual funds across AMCs via CAMS/KFintech, receives the periodic CAS by email, is comfortable dropping a file into a web page, and is privacy-conscious enough to value that nothing is uploaded.

Secondary users

- **The financially literate "power" investor / DIY financial planner** — wants XIRR, per-lot capital gains, rolling returns, and benchmark comparison without exporting data to a commercial tool.
- **Family "portfolio helper"** — a more technical family member reviewing a relative's consolidated statement on their behalf, locally.

Explicit non-audience (v1.0): institutional users, advisers managing many client books, demat/equity (NSDL/CDSL) holders, and non-Indian market portfolios. See §3 MoSCoW "Won't Have".

1.4 Success Metrics (KPIs)

Category	Metric	Target
Correctness	Golden-fixture statement-only totals reconcile to the rupee across all bundled fixtures	100% (CI-enforced)
Correctness	Live-NAV portfolio total within plausibility band of statement total	100% of held funds pass the $\frac{1}{3}\times-3\times$ gate or fall back with a stated reason
Performance	Time to first meaningful paint (statement-only analysis, no network) on a mid-range laptop	< 1.5 s
Performance	Time to fully revalued dashboard (live NAV + benchmark resolved)	< 4 s on a typical connection
Privacy	Outbound requests carrying statement PII (PAN / folio / amounts / the PDF itself)	Zero (must be verifiable — NFR S3)
Reliability	Graceful degradation: a fund whose live NAV can't be fetched still renders on statement NAV with a labelled reason	100% (no blank/NaN cells)

Category	Metric	Target
Trust	Every displayed valuation is traceable to a named source (live / statement) in the Data Sources panel	100% of funds
Quality	Automated test suite green on every change	429/429 Vitest + 2/2 Playwright e2e passing (up from 157/157 at v1.0.0)
Accessibility	WCAG 2.1 AA on the default (lean) view	Met (workstream A + review Theme B — contrast, <code>aria-live</code> , focus trap, table semantics)
Empowerment	Portfolio surfaces at least one actionable, data-derived observation (not just numbers) without requiring any input	100% — the "Worth a Look" flags (expense ratio, benchmark underperformance, concentration) and the Insight card compute from data already on hand

2. User Personas & Core Journeys

2.1 Personas

Persona A — "Priya", the Privacy-Conscious Retail Investor (Primary)

- **Profile:** 34, salaried, invests monthly via SIPs across 6–8 funds and 3 AMCs. Receives the CAMS CAS email quarterly.
- **Goals:** Know her real return, understand her equity/debt mix, see whether she's beating a plain index fund, get a plain-English read on whether her allocation fits her age — all without handing her financial life to a website.
- **Frustrations:** Doesn't trust "upload your statement" services. Finds the raw CAS impenetrable. Doesn't know her XIRR. Isn't sure if her allocation is age-appropriate.
- **What success looks like for her:** Drops the PDF, immediately sees "You're balanced with 61% equity... XIRR 7.1% vs Nifty 50 -0.7%", and trusts it because nothing left her browser.

Persona B — "Rahul", the DIY Power Investor (Secondary)

- **Profile:** 41, engineer, tracks everything in spreadsheets, holds 25+ schemes including switched/renamed funds.
- **Goals:** Per-lot STCG/LTCG for tax planning, rolling 1-year returns, per-AMC concentration, provenance for every NAV, the ability to audit the methodology.
- **Frustrations:** Spreadsheets can't do XIRR across many dates or per-lot gains cleanly; commercial tools are black boxes.
- **What success looks like for him:** Opens "Full Holdings", "Fund Houses", "Method Notes", and "Data Sources"; confirms the numbers tie out and the methodology is documented.

Persona C — "The Maintainer" (Operator / Developer)

- **Profile:** Maintains and extends the app; there is **no runtime administrator** because there is no server or account system.

- **Goals:** Add new statement fixtures, keep the parser tolerant of new CAS layouts, keep the NAV layer reliable, ship the deferred hardening (a11y, security, deploy) without regressing the golden totals or the privacy invariants.
- **Frustrations:** Silent data-source drift (a benchmark fund that quietly stopped reporting); display bugs a green test suite doesn't catch.

2.2 Core User Journeys

Journey 1 — First-Use / Onboarding (Priya)

1. Priya opens the app URL. It **loads a bundled sample statement immediately** so the dashboard is never empty on arrival, with an explicit **"This is sample data"** callout in the content area (not just a small masthead label) so she can't mistake it for her own numbers.
 2. She sees the **Command Deck**: a data-check headline, her (sample) portfolio summary, KPI tiles, a value-vs-invested chart, top holdings, and an allocation donut — every jargon term (XIRR, ST-LT Split, Wtd. CAGR, Expense Ratio, Riskometer, ...) carries a small ⓘ **point-of-use explainer**, reachable by hover or tap/keyboard, so she never has to leave the page to look something up.
 3. She drags her own CAS **PDF** onto the upload bar — a **permanently-highlighted drop zone** (amber dashed border, full-contrast text in both themes), not one that only becomes visible on hover. It is parsed **in her browser** (pdf.js); the dashboard repaints with statement-only figures within ~1 second.
 4. In the background the app fetches **live NAVs** and the **Nifty 50 benchmark**; the tiles upgrade to current valuations with a "Live NAV" tag and an "as of" date.
 5. The **Data Check** headline confirms "all N holdings valued on live NAVs" (or names the exceptions) in plain language — what happened, whether the numbers can be trusted, what to do next — before any term of art.
 6. If she prefers a different visual register, a **Terminal Deck / The Ledger** theme toggle switches the whole app between a dark monospace look and a warm paper/serif light theme, instantly, no reload.
- **Acceptance:** No blank state; statement PII never transmitted; live upgrade is non-blocking; sample data is unambiguous; a render error anywhere in the dashboard shows a recoverable fallback (React error boundary) instead of a blank page.

Journey 2 — Core Workflow: Understand, Benchmark & Act (Priya)

1. Priya reads the KPI rail: **Total Value / Invested, Total Gain with ST-LT split, XIRR (All-Time) and (1Y) each with the Nifty 50 figure beneath**, and a visually-promoted **Insight** card (teal accent, full-strength text — no longer visually equal-weighted with the jargon-dense tiles beside it) giving the one plain-English takeaway without requiring any input.
2. Above the chart/holdings grid she sees a **"Worth a Look"** strip — a small number of specific, data-derived flags computed from information the engine already has: a fund whose expense ratio is high for its category, a fund lagging its own stated benchmark, or a single holding concentrated enough to dominate the portfolio's swings. This is the first concrete step from "display" to "empower": the app tells her what to look at, not just what the numbers are.
3. She clicks **Full Commentary**, enters her **age** and **target retirement age**; the commentary tailors its glide-path guidance to her computed years-to-retirement **and projects an actual retirement corpus** (conservative vs. expected scenario, side by side) from her current value and historical contribution rate — not just a qualitative risk-band verdict.

4. She taps an allocation slice to drill into the funds contributing to Equity/Debt/Cash/Other.
- **Acceptance:** XIRR and benchmark are visibly comparable; commentary materially changes with age; the corpus projection changes materially with age/retirement-age inputs; Worth a Look flags only fire when a real threshold is crossed (no flag on an unremarkable portfolio); drill-down is keyboard- and pointer-accessible.

Journey 3 — Deep Audit (Rahul)

1. Opens **Portfolio Analysis** and selects **Full Holdings** → per-scheme value, gain, and CAGR. Selecting another section replaces it (accordion); **View All** expands everything at once.
 2. Opens **6-Chart Gallery** and steps through Invested-vs-Value, Calendar-Year Returns, Rolling 1-Year, Net Capital by Year, Holdings by Value, and Geography.
 3. Opens **Data Sources** to confirm every NAV's provenance and the per-fund data-check status; opens **Method Notes** to audit methodology.
 4. If he spots something worth reporting (a parsing edge case, a suggestion), he opens **Feedback** from the Help menu — a short categorized form that posts to a small privacy-respecting relay (local dev server or a Cloudflare Pages Function in production, never a third-party form service), sharing the same category list and length cap on both.
- **Acceptance:** Numbers reconcile to the headline; every NAV is attributed; methodology (including the Nifty 50 proxy caveat) is disclosed; Feedback submission never includes statement data.

Journey 4 — Degraded / Offline (both)

1. The network is unavailable or a NAV endpoint fails.
 2. The app **still renders** using statement NAVs; the Data Check panel names each fund on statement NAV and why; the benchmark comparison is **left blank rather than guessed**.
- **Acceptance:** No crash, no NaN, no misleading stale figure presented as current.

3. Functional Requirements (Scope & Features)

3.1 Feature Breakdown (as-built)

F1 — Ingestion (three routes, one parser)

- **PDF** dropped/selected → extracted in-browser via **pdf.js** (positioned text runs → reassembled lines).
- **Markdown** `.md` file or **pasted text** → passthrough.
- **"Convert PDF to Markdown"** → posts the PDF to a **local** Markdown bridge (`127.0.0.1:8765` , `markdown_server.py`) that runs on the user's own machine; returns Markdown to the same parser.
- A source-agnostic `normalizeInput()` flattens Markdown tables so all three routes parse **identically**.

F2 — CAS Parsing (CAMS + KFintech)

- Position-independent, pattern-based extraction of schemes, folios, ISINs (including wrapped and O↔O-variant ISINs), NAV/market-value/cost/closing-units in any order, and every transaction (buys, sells, switches, stamp duty, segregated folios).
- Extracts the **account-holder name** for the personalised masthead (first name only, privacy).

F3 — Analytics Engine (pure, no DOM / no network)

- **Returns:** per-fund and portfolio **XIRR** (money-weighted, all-time), **trailing 1-year XIRR** (money-weighted, 12-month window with a synthetic start-of-window value), weighted **CAGR**, **Modified-Dietz** calendar-year and rolling 1-year returns, since-inception money-weighted return.
- **Capital gains:** per-lot **STCG/LTCG** (12-month equity / 24-month debt threshold), realised gains from round-trips.
- **Allocation:** look-through **Equity / Debt / Cash / Other** roll-up from curated fund metadata; **geographic** concentration estimate.
- **Roll-ups:** per-AMC ("Fund Houses"), inception date/span, exited-folio handling (hidden from holdings, retained in realised gains and since-inception return).

F4 — Live-NAV Valuation

- Resolves each holding's latest NAV via a **cached AMFI** `NAVA11.txt` **edge function** (primary, N2–N3) with **mf.captmemo.in** (ISIN) and **mfapi.in** (name search) as CORS-native fallback sources.
- **Plausibility gate:** a candidate NAV outside $\frac{1}{3}\times$ – $3\times$ of the statement NAV is rejected as a wrong-fund match and rescued from the next source, or the fund falls back to statement NAV with a stated reason.
- Revalues market value, gains, XIRR, and allocation to the latest NAV date. 180-second in-memory cache; **Refresh** forces a refetch.

F5 — Nifty 50 Benchmark Comparison

- Fetches a real, low-cost, direct-plan, growth-option **Nifty 50 index fund's full NAV history** from mfapi.in as a **disclosed proxy** for the index (no reliable public raw-index API exists).
- Filters near-miss variants (Next 50, equal-weight, quality, value); **skips stale/wound-up schemes** (recency check) and, among still-reporting candidates, prefers the **longest history** so older portfolios' all-time window isn't clipped.
- Computes the benchmark's CAGR over the portfolio's all-time span and over the trailing year; displays beneath the portfolio's own XIRR figures. Left **blank when no confident match** — never guessed.

F6 — Data Check (trust surface)

- After every load/refresh, audits coverage and reconciles holdings → headline value; renders a single concise **pass/fail headline** above the deck with a link into **Data Sources** for the per-fund breakdown.

F7 — Educational Commentary

- Collapsible; takes **age** and **target retirement age** → **years-to-retirement = retirementAge – age** → horizon-tailored equity-band guidance, a glide-path explainer, and a portfolio assessment through a Bogle/Boglehead lens, with book/wiki references and a **SEBI-RIA "not personalised advice" disclaimer**.

F8 — Visualisation & Tables

- **6-Chart Gallery** (carousel): Invested-vs-Value, Calendar-Year Returns, Rolling 1-Year, Net Capital by Year, Holdings by Value, Geography.
- **Allocation donut** with click/tap drill-down; **sortable** Full Holdings and Fund Houses tables; **Fund Cards** with KIM/SID detail; **Data Sources** provenance; **Method Notes**.

F9 — Point-of-Use Explainers (added post-v1.0.0, review item A1)

- A small ⓘ **InfoTip** affordance beside every jargon-dense label (the 4 KPI tile headers, sortable-table column headers, Fund Card stat labels): hover-revealed for a mouse, click/Enter-toggled for touch and keyboard. Reuses copy already written for the FAQ/Method Notes — no duplicated content.

F10 — Actionable Insight Flags ("Worth a Look") (review item A2)

- Computed from data the engine already has, with no extra input required: **(a)** an expense-ratio flag when a fund's cost is high for its category; **(b)** a per-fund underperformance flag against the fund's *own* stated benchmark; **(c)** a concentration flag when one holding dominates the portfolio. Rendered as a short, specific list — not a generic warning.

F11 — Retirement Corpus Projection (review item A3)

- Inside Commentary, given age + target retirement age (already collected) plus current value and historical contribution rate (already parsed), projects the corpus at retirement under conservative and expected scenarios, side by side — turning the qualitative risk-band verdict into an actual planning number.

F12 — Dark / Light Theme Toggle ("Terminal Deck" / "The Ledger")

- Instant, no-reload toggle between a dark monospace ("Terminal Deck," JetBrains Mono) and a warm paper/serif light theme ("The Ledger," Fraunces + Courier Prime), driven entirely by CSS custom properties — every component reads the same token set, so no component can be silently left in one theme. Both palettes independently meet WCAG AA text-contrast.

F13 — Feedback

- A short categorized feedback form (Bug Report / Feature Request / General Feedback, length-capped), reachable from the Help menu, posting to a small relay that runs locally in dev and as a Cloudflare Pages Function in production — never a third-party form service, and never carrying statement data.

F14 — Installability shim

- A web app manifest + description/theme-color meta tags let a browser offer "Add to Home Screen" / desktop install. Deliberately **no service worker or offline caching** — the app's value depends on a live NAV fetch every load, so an offline shell would be actively misleading, not a feature.

3.2 MoSCoW Prioritization Matrix

Priority	Requirement	Rationale / Status
Must Have	Client-side CAS parsing (CAMS + KFinTech), zero statement egress	Core privacy promise — built

Priority	Requirement	Rationale / Status
Must Have	XIRR (all-time + 1Y), CAGR, STCG/LTCG, look-through allocation	Core analytics — built
Must Have	Live-NAV revaluation with plausibility gate + graceful fallback	Trust & correctness — built (AMFI edge fn primary, N2–N3)
Must Have	Data Check reconciliation + per-fund provenance	Trust surface — built
Must Have	Golden-fixture correctness gate in CI	Regression safety — built
Should Have	Nifty 50 benchmark comparison (disclosed proxy)	Differentiator — built
Should Have	Age-tailored educational commentary + retirement corpus projection	Differentiator — built (F7, F11)
Should Have	WCAG 2.1 AA accessibility pass	Public-product bar — built (workstream A + review Theme B)
Should Have	Strict CSP, SRI, no-PII-egress automated test	Public-product bar — built (workstream S)
Should Have	Cached AMFI edge function (primary NAV source)	Scale & reliability — built (tasks N2–N3)
Should Have	Point-of-use explainers + actionable insight flags	"Empower, not just display" — built (review items A1, A2)
Could Have	Per-year hover tooltip on the value-vs-invested chart	Polish — built (task U2a)
Could Have	IndexedDB same-day NAV cache	Perf/offline nicety — built (task N4)
Could Have	Playwright end-to-end smoke + a11y checks	Confidence — built (task T1)
Could Have	Installable PWA manifest (no offline SW)	Convenience — built (review item E3)
Could Have	Dark/light theme toggle	Polish — built (task U6)
Could Have	SIP-pattern detection, fund-overlap analysis, tax-loss-harvesting hints	Competitor table stakes — deferred (review item A7 — each is a feature-planning exercise, not a fix)
Could Have	Touch support for chart tooltips	Mobile parity — deferred (review item B5, bundled with a future mobile-optimization pass)
Won't Have (v1.0)	User accounts / authentication / server-side persistence	Breaks the privacy model by design
Won't Have (v1.0)	CSV / equity / NSDL-CDSL demat ingestion	Premature generalization — deferred behind a documented seam
Won't Have (v1.0)	Multi-statement merge over time	Post-launch roadmap

Priority	Requirement	Rationale / Status
Won't Have (v1.0)	Any third-party analytics or error tracking on data routes	Privacy guardrail (§8)
Won't Have (v1.0)	Offline service-worker caching	Marginal while NAVs need network; would mislead about data freshness — deferred (X4)

3.3 Representative User Stories (with Acceptance Criteria)

US-1 — Instant, private analysis

As a privacy-conscious investor, I want to drop my CAS PDF and see my portfolio analysis without anything being uploaded, so that I can understand my holdings without surrendering my financial data.

- **Given** a valid CAMS/KFintech CAS PDF, **when** I drop it on the upload bar, **then** the dashboard repaints with statement-only figures in under ~1.5 s and **no** network request contains the PDF, PAN, folios, or amounts.
- **Given** the same file, **when** parsing completes, **then** live NAVs and the benchmark load asynchronously and upgrade the figures without blocking the initial paint.

US-2 — Money-weighted return

As an investor who contributed on many dates, I want my true XIRR, so that I'm not misled by a naive value ÷ cost ratio.

- **Given** a portfolio with multiple dated cash flows, **when** analysis runs, **then** the All-Time figure is the money-weighted XIRR over every dated flow to the valuation date.
- **Given** ≥ 12 months of history, **when** analysis runs, **then** a trailing 1-year XIRR is shown; **given** < 12 months, **then** the 1-year figure is blank (no fabricated window).

US-3 — Benchmark honesty

As an investor, I want to compare my return to a Nifty 50 index fund over my own holding period, so that I can judge whether my choices added value — without being shown a fabricated number.

- **Given** a resolvable, currently-reporting Nifty 50 index fund, **when** the benchmark loads, **then** its CAGR over my all-time and 1-year spans appears beneath my XIRR figures, labelled as a fund proxy.
- **Given** no confident, non-stale match, **when** resolution fails, **then** the benchmark line is left blank and the Method Notes explain why.

US-4 — Graceful degradation

As a user on a flaky connection, I want the dashboard to still work, so that a network failure never blocks or corrupts my view.

- **Given** a NAV endpoint fails, **when** the dashboard renders, **then** affected funds use statement NAV, the Data Check names them with a reason, and no cell shows NaN/blank.

US-5 — Horizon-aware guidance

As an investor, I want commentary tailored to my years-to-retirement, so that the guidance actually fits my stage of life.

- **Given** an age of 30 and a target retirement age of 60, **when** commentary generates, **then** it reflects ~30 years to retirement; **given** age 55 / target 60, **then** the guidance is materially more conservative.
- **Given** a target retirement age $\leq$ current age, **when** validated, **then** a clear correction message is shown.

US-6 — Told what to look at, not just what the numbers are

As an investor who doesn't know what "good" looks like, I want the dashboard to flag anything genuinely worth my attention, so that I don't have to already be an expert to notice a high-cost fund or an over-concentrated position.

- **Given** a fund whose expense ratio is materially above its category norm, **when** the dashboard loads, **then** it appears in "Worth a Look" with a plain-English reason.
- **Given** a portfolio where no fund crosses any flag threshold, **when** the dashboard loads, **then** "Worth a Look" shows nothing — the feature never manufactures a concern to seem useful.
- **Given** any jargon-dense label (XIRR, Wtd. CAGR, Expense Ratio, ...), **when** the user hovers or taps its ⓘ, **then** a plain-language 1–2 sentence explanation appears without navigating away.

4. Non-Functional Requirements (NFRs)

4.1 Performance & Scalability

- **First meaningful paint (statement-only, no network):** < 1.5 s on a mid-range laptop for a typical statement (tens of schemes, hundreds of transactions).
- **Full revaluation (live NAV + benchmark):** < 4 s on a typical connection; the live upgrade is always **non-blocking** (statement-only render first).
- **Compute:** the engine is pure and runs in milliseconds for realistic statements; a Web Worker remains **deliberately deferred** (X3) until profiling shows real jank (statements are tiny; pdf.js already runs off the main thread).
- **Caching (built, N2–N4):** a **cached AMFI edge function** (one fetch/day for all users, CDN-cached, keyed by ISIN) is now the **primary** NAV source, with the CORS-native `mf.captmemo.in` / `mfapi.in` sources as fallback — a large reduction in per-user, per-ISIN hits to the hobby endpoints that were the primary source at v1.0.0. An optional **IndexedDB same-day cache** (N4) sits in front of that for repeat same-day loads; a 180-second in-memory cache remains the innermost layer; **Refresh** forces a full refetch through all layers.

- **Scalability model:** the app is a **static SPA**; user concurrency scales with static hosting/CDN. The one shared backend is the stateless, cache-heavy AMFI edge function (Cloudflare Pages Function).

4.2 Security & Compliance

- **Threat model is inverted vs a typical SaaS:** there is **no user account, no server-side session, and no database of user data**, so the classic auth/RBAC attack surface does not exist. This is a deliberate design decision, not an omission.
- **Data-egress boundary (the core control):** the only outbound requests are (a) public NAV lookups by **scheme name or ISIN** (now routed primarily through the AMFI edge function, N2–N3), (b) the Nifty 50 index-fund NAV history, and (c) static assets (fonts/pdf.js, all self-hosted). The statement, PAN, folio numbers, holdings, and amounts **must never** be transmitted — **automatically verified** by `marketdata/egress.spec.ts`, which spies on every `fetch()` `resolveLiveNavs()` / `fetchNiftyBenchmark()` make and asserts (a) the host is one of an explicit allow-list, and (b) no folio number or rupee amount ever appears in a request URL (S3, **built**).
- **Local-only optional bridges:** the MarkItDown "Convert PDF to Markdown" path posts only to `127.0.0.1:8765`; the local Feedback relay dev server listens on `127.0.0.1:8766` — both are opt-in, localhost-only, and never leave the device. The CSP's `connect-src` allow-list is the enforced boundary for both.
- **In-transit:** all external calls over **TLS 1.3**; app served over HTTPS.
- **At-rest:** no server persistence in v1.0. Any future opt-in local snapshot must use **WebCrypto (AES-256-GCM)**, **passphrase-derived key**, and default to **not** persisting.
- **Content-Security-Policy & SRI (S1, built):** a strict `default-src 'self'; script-src 'self'` CSP (no inline/eval script; `style-src` keeps `'unsafe-inline'` only for React's own inline `style=""` attributes and the Vite dev server's injected `<style>` tags — a documented, much lower-severity relaxation than script-src); self-hosted pdf.js worker and fonts (zero CDN script/font execution, so no SRI gap to manage); `connect-src` is an explicit allow-list of the NAV sources plus the two localhost bridges; `object-src 'none'`.
- **XSS hardening — fully complete (S2, then X5/R16):** at v1.0.0 the chart/commentary/notes components used `dangerouslySetInnerHTML` string-builder sinks with manual `escapeHtml()` calls on statement-derived interpolation. All six chart components were converted to real JSX during the U-series interactivity work; `Commentary.tsx`'s `buildCommentaryHTML` — the last remaining sink — was converted to `buildCommentaryContent(): ReactNode` in review item C6 (R16, 2026-07-13). **Zero `dangerouslySetInnerHTML` usages remain anywhere in `app/src`** (verified by grep, not just by the two components that used to need it) — React's own text-escaping now does the job the manual `escapeHtml()` used to do, structurally rather than by discipline.
- **Compliance posture:** because no personal data is collected, transmitted, or stored server-side, **GDPR/DPDP-style data-controller obligations are minimised by architecture** rather than by policy. A visible in-app privacy statement (D2, **built**) — reachable from the Help menu's "Privacy and Data" panel — states exactly what leaves the device, including the same fetch-spy invariant `egress.spec.ts` enforces in code. The product is **not** a HIPAA/PCI system and handles no card/health data.

4.3 Accessibility (a11y) — WCAG 2.1 AA, built (workstream A + review Theme B)

- Full **keyboard operability** for the donut slices, legend, sortable headers (native `columnheader` role preserved — sort interaction moved to a nested button rather than `role="button"` on the `<th>` itself, review item B4), chart gallery (prev/next/dots, plus per-chart hover/keyboard tooltips via a shared `InteractiveChartFrame`), accordion section buttons, commentary toggle/inputs, InfoTips, and the file drop zone; visible focus rings throughout.
- **aria-live regions (B2)** on upload status, Data Check results, and live-NAV completion — async state changes are now announced to screen readers, not silently invisible.
- **Modal focus trap + focus-restore-on-close (B3)** via one shared `<ModalShell>`, covering both the Help and Feedback modals.
- **AA contrast, both themes:** the dark theme ("Terminal Deck") passed from the start; the light theme ("The Ledger") had two failing secondary-text colors (`--brass` 2.59:1, `--muted` 3.78:1 against `--paper`) found and fixed (B1) to 4.84:1/5.14:1 — both now clear WCAG AA's 4.5:1 body-text threshold, measured programmatically, not eyeballed.
- **prefers-reduced-motion** honoured across gallery transitions, spinners, and the hover-lift effect (which is zeroed outright, not just sped up, matching the pre-existing framer-motion behavior it replaced).
- **Verification:** live keyboard-only walkthroughs in both themes at desktop and mobile widths for every landed item, plus the full automated suite; a dedicated automated axe check remains a nice-to-have, not yet wired into CI.

4.4 Reliability & Availability

- **Static-host availability target:** 99.9% (inherited from the CDN/static host).
 - **AMFI edge function (built, N2) target:** 99.9%, but the app is designed so **any** NAV failure degrades gracefully to statement NAV — availability of the analysis does **not** depend on NAV availability. Verified live (not just in tests): with all live sources unreachable, the dashboard still renders on statement NAV with the Data Check naming the fallback and why.
 - **Whole-app render resilience (R11):** a React error boundary wraps the dashboard content (not the upload bar or theme/help controls, which stay usable even if the wrapped content crashes) — a render error on an unanticipated edge case in real-world statement data now shows a friendly recoverable fallback instead of blanking the entire page. Resets automatically once fresh data loads (Clear Data / Refresh), giving the user one real click back to a working dashboard.
 - **No data-loss risk by design:** nothing user-specific is stored server-side, so there is no backup/disaster-recovery obligation for user data. Source, fixtures, and docs are version-controlled.
 - **Correctness reliability:** the golden-fixture suite (rupee-exact totals) plus the plausibility gate and benchmark-staleness check are the reliability backbone; CI blocks any drift. A newer **staleness canary** (review item E2) makes a second, subtler class of drift visible too:
`reference/fundMetaCoverage.spec.ts` asserts the exact count of schemes falling back from the hand-curated `FUND_META` table to keyword-based inference per real fixture, so a silent coverage regression in curated reference data shows up as a failing test instead of an invisible quality drop.
-

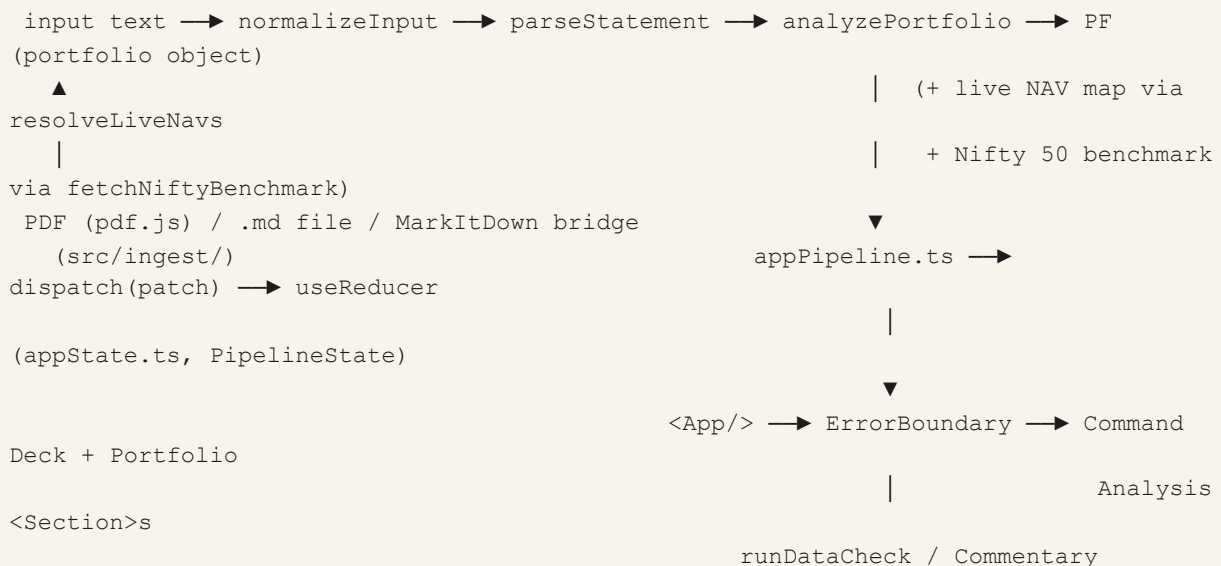
5. Technical Architecture & Data Strategy

5.1 Tech Stack (as-built)

Layer	Choice	Notes
Language	TypeScript ~6.0 (strict)	Financial math + a messy parser both depend on the type system.
Framework	React 19 + Vite 8	Component model; Vite dev server & build.
PDF extraction	pdfjs-dist ^6.1 (in-browser)	Lazy-loaded; needs browser APIs (<code>DOMMatrix</code>).
Alt. extraction	Markdown via local bridge (<code>markdown_server.py</code>)	Opt-in, localhost-only; cleaner table reconstruction.
Engine / parser	Pure TS modules, zero deps, no DOM/fetch	Publishable/reusable in isolation.
Market data	AMFI edge function (built, primary — N_2/N_3) + <code>mf.captmemo.in</code> (ISIN) / <code>mfapi.in</code> (name) CORS-native fallback	Prices only; plausibility-gated.
Charts	Hand-rolled inline SVG, shared interaction primitives (<code>InteractiveChartFrame</code> , R15)	Dependency-free, print-clean, on-brand.
Styling	CSS custom properties + design tokens (<code>ui/tokens.css</code> , <code>ui/app.css</code> , <code>ui/deck.css</code>)	Dual dark/light theme ("Terminal Deck"/"The Ledger"), instant toggle, both AA-contrast.
Testing	Vitest 4 (429 unit + golden-fixture tests, up from 157); Playwright e2e (2 critical-path tests, CI-wired, T1 built)	Network fully fetch-mocked.
Tooling	oxlint, Prettier, <code>tsc -b --noEmit</code> ; CI = 2 jobs (unit + e2e)	Fast lint; project-reference typecheck.
Prod dependencies	7: <code>react</code> , <code>react-dom</code> , <code>pdfjs-dist</code> , <code>html-to-image</code> ("Save as PNG"), 3 self-hosted <code>@fontsource</code> packages (JetBrains Mono / Fraunces / Courier Prime)	<code>framer-motion</code> removed (R12, review item C5) — its one hover-lift effect is now plain CSS. Deliberately minimal attack/bloat surface.
Deploy	Static SPA + AMFI edge function + feedback webhook, both Cloudflare Pages Functions — built and verified locally (D1); account/push steps are the operator's	See tasks D1.

5.2 System Architecture

Client-first, (nearly) backend-less. The interaction model is not a request/response API to an application server; it is a **local pipeline** with a single, narrow, price-only network egress:



- **Pure core** (`engine/` , `parsing/` , `reference/`) has no React, DOM, or `fetch` — it could ship as an npm package or run in a CLI.
- **Network layer** (`marketdata/`) is the *only* egress and returns prices keyed by ISIN/name.
- **UI orchestration is decomposed** (R17, review item C1 — the single highest-priority item from the 2026-07-12 review): `App.tsx` shrank from 403 lines of inline `useState` / `setState` orchestration to ~185 lines of pure wiring. `appState.ts` holds a `useReducer` "patch reducer" (`PipelinePatch = Partial<PipelineState> | ((state) => Partial<PipelineState>)`) so what used to be 3–8 sequential `setState` calls per async handler — with intermediate, potentially-inconsistent render states possible between them — is now one atomic dispatch. `appPipeline.ts` holds the actual orchestration (`runPipeline` , `handleFile` , `handleConvertMarkitdown` , password retry, ...) as plain, React-free functions with an injectable `fetch` , directly unit-testable without mocking React (16 new tests, `appPipeline.spec.ts`). `Section.tsx` is the shared shape for all 6 Portfolio Analysis sections.
- **UI layer** (`features/` , `charts/` , `ui/` , `App.tsx`) is a thin, stateful shell over the pure core, now wrapped in a React **error boundary** (R11) around the dashboard content.
- **API paradigm**: the external NAV sources are consumed as simple **REST/JSON over HTTPS**; there is no GraphQL and no first-party application API in v1.0. The **built** AMFI edge function (`functions/api/amfi-navs.ts` , N2) is a single stateless REST endpoint returning an `ISIN→{nav,date,name}` map with permissive CORS, CDN-cached daily. A second, structurally identical Cloudflare Pages Function (`functions/api/feedback.ts`) relays the Feedback form in production.

5.3 Data Model & Schema (in-memory domain model)

There is **no database**; these are the in-memory TypeScript entities produced by the pipeline and consumed by the UI.

Entity	Key Fields (types)	Relationships
Statement (text)	raw normalized text	1 → many <code>Scheme</code>

Entity	Key Fields (types)	Relationships
Scheme	house (str), name (str), isin (str), folio (str), nav (num), navDate (Date), marketValue (num), closingUnits (num), costValue (num)	1 → many Txn
Txn	date (Date), units (num; +buy / -sell), amount (num), price (num), stamp (num)	many → 1 Scheme
Fund (analyzeScheme result)	marketValue, unrealised, per-lot stcg / ltcg, realised, cagr, navLive, navSource, liveName, active (bool), hasCostBasis (bool), allocAmt, meta	derived 1:1 from Scheme
FundMeta (reference/fundMeta.ts)	keyed by ISIN: category, alloc: {equity, debt, cash, other}, geo?, benchmark, expense, launch, exit, amc, note	many Scheme → 1 FundMeta (by ISIN)
BenchmarkPoint	date (Date), nav (num)	series for the Nifty 50 proxy fund
PF / Portfolio (top-level result)	funds[], totalValue, totalCost, unrealised, realised, xirr, portXirr1Y, allTimeReturn, portCagr, inceptionDate, inceptionYears, alloc: {equity, debt, cash, other}, geo: [{country, pct}], houses: [{house, cost, value, hasCost}], series: {line, annual, rolling, drawdown, contrib, ...}, live, liveMatched, liveAsOf, liveSource, valDate	aggregates all Fund s
PipelineState (AppState.ts, UI-side, not part of the engine's domain model)	pf, diag, status, uploadPhase, extraction, pendingPassword, investorName, isSample, niftyAllTime, nifty1Y	one useReducer state shape for everything a pipeline run (upload/refresh/convert) can change atomically

Note: the `series` object still computes a `drawdown` TWR index internally; the **Drawdown chart** was removed from the gallery (Revision 4), but the series field is retained for correctness of other views and potential reuse.

Missing-value convention (documented, review item C3/R14): the domain model uses two coexisting, now-explicitly-documented conventions for "this value is missing" — `T | null` for a *structural* absence (not enough data to define the value at all — `xirr`, `cagr`, `portXirr`, ...) vs. a plain `number` carrying `NaN` for a *data-quality* gap (a specific field the statement didn't supply — `avgCost`, `costValue`, `unrealised`, ...), always paired with a sibling boolean (`hasCostBasis`) or an `isFinite()` guard. A single shared `isSchemeHeld()` / `MIN_HELD_UNITS` helper (previously copy-pasted, and subtly diverged, across 3 files) is now the one place "is this holding still open" is decided.

5.4 Reference & Provenance Data

- `reference/fundMeta.ts` — hand-curated, ISIN-keyed metadata for funds encountered; **intentionally not expanded into a large database** (unknown funds fall back to keyword inference).
- `reference/aliases.ts` — known scheme renames for harmonisation.
- `reference/geo.ts` — country-exposure **estimates** (the CAS discloses no country split).

6. UI/UX & Design System Guidelines

6.1 Design Principles

- **Quick-glance first, depth on demand.** The default view (the "Command Deck") answers "how am I doing?" at a glance; everything deeper opens from a permanent **Portfolio Analysis** accordion.
- **Explain in place, don't make the user go looking.** Every jargon-dense label carries a point-of-use ⓘ explainer (F9); a small "Worth a Look" strip (F10) surfaces the handful of things actually worth the user's attention, unprompted.
- **Responsive, desktop-optimised, seam-free.** A 3-tier breakpoint contract (640 / 860 / 1023, review item D2) replaced five previously-uncoordinated values that used to leave a broken 781–1023px range where fixed-position corner buttons could float over an already-narrow-collapsed layout; no horizontal scroll at any width, 320px up.
- **Trust through traceability.** Every number is attributable; the Data Check headline is always visible, in plain language before jargon; caveats are disclosed, not hidden.
- **Two full themes, one set of tokens.** "Terminal Deck" (dark, JetBrains Mono) and "The Ledger" (light, Fraunces + Courier Prime) toggle instantly, no reload; every component reads the same CSS custom-property set so nothing can be silently left in one theme.
- **Craft rules:** `font-variant-numeric: tabular-nums` on all figures; Title Case on every label/header/button; a single positive-delta accent colour per theme; a permanently-highlighted (not hover-only) primary call to action (the upload drop zone).

6.2 Information Architecture

```
Portfolio Dashboard (single page)
├ Theme toggle (Terminal Deck / The Ledger) + Help Menu (Instructions / Reading the
  | Dashboard / Privacy and Data / FAQ / Feedback) – fixed corners on desktop,
collapse
├ into a static mobile row above Data Check at ≤1023px (review item D2)
├ Upload Bar (permanently-highlighted drop zone / browse / paste / Convert PDF to
Markdown)
├ Sample-data callout (first paint only, review item A5) – explicit, not just a
masthead label
├ Data Check headline (plain-language-first, review item A6) →(link)→ Data
Sources
├ Command Deck (wrapped in an error boundary, R11 – a render error here shows a
  | | recoverable fallback, not a blank page)
  | └ Masthead – "«First name»'s Portfolio Summary" · As of «date» · Live NAV ·
Refresh
  | └ KPI Rail (4 tiles, each label carrying an ⓘ InfoTip, review item A1)
  |   └ Total Value / Total Invested
  |   └ Total Gain / ST-LT Split
  |   └ XIRR (All-Time) & (1Y) – each with Nifty 50 figure beneath
  |   └ Insight – visually promoted (teal accent), review item A4 →(link)→
Full Commentary
  | └ Worth a Look – expense/benchmark/concentration flags, review item A2 (renders
nothing
  |   when no threshold is crossed)
  |   └ 2-column grid (collapses to 1 column ≤1023px)
  |     └ Left: Value-vs-Invested chart (per-year hover/keyboard tooltip, U2a) +
Top-5 Holdings
  |       └ Right: Allocation donut + legend (height-matched to the left column)
├ Portfolio Commentary (collapsible; age + target retirement age → glide-path
guidance
├ + retirement corpus projection, review item A3)
└ Portfolio Analysis (accordion; "View All" opens all six; each is a shared
<Section>, R17)
    └ 6-Chart Gallery    └ Full Holdings    └ Fund Houses
    └ Fund Cards         └ Data Sources    └ Method Notes
Footer – "Not investment advice." · As of «date»
```

6.3 Key Screen Specifications & State Behaviour

Region	Layout / Component Expectation	States
Upload Bar	Permanently-highlighted drop zone (accent dashed border, full-contrast text — not hover-only) + browse + "Convert PDF to Markdown" + "Load Sample Statement".	<i>Idle</i> prompt (always visible, not just on hover); <i>Reading...</i> / <i>Converting...</i> ; <i>Error</i> (wrong file type, bridge unreachable) with actionable text.
Data Check	One-line pass/fail headline, plain-language-first (A6); link to Data Sources.	<i>Pass</i> ("all N holdings valued on today's official price"); <i>Partial</i> (names how many, and why); renders nothing until a live-NAV attempt has occurred. <code>role="status"</code> <code>aria-live="polite"</code> (B2) — a screen-reader user is notified when this appears/changes, not left unaware.

Region	Layout / Component Expectation	States
KPI Rail	4 equal tiles, each label with an ⓘ InfoTip (A1); XIRR tile shows All-Time & 1Y in the accent colour, Nifty 50 comparison beneath each.	<i>Live</i> figures with tag; <i>statement-only</i> pre-live; benchmark line <i>blank</i> when unresolved.
Worth a Look	Amber-accented card, full width, between the KPI row and the chart/holdings grid (A2).	<i>Hidden</i> when no flag threshold is crossed; <i>N items</i> listed with a plain-English reason each.
Value-vs-Invested chart	Labelled ₹ (lakh/crore) Y-axis + year X-axis; solid value line + dashed invested line + legend; shared hover/keyboard interaction shell (<code>InteractiveChartFrame</code> , R15) across all 6 gallery charts.	Per-year hover/keyboard tooltip — built (U2a).
Allocation donut	Fixed-ratio donut + legend (240px base / 276px in the 2-col deck card / 220px on ≤640px mobile, review item D3); centre shows Total Value; slices drill down to contributing funds.	<i>No selection</i> prompt; <i>selected</i> slice lists funds; fully keyboard-selectable (arrow keys + Enter, focus ring).
Portfolio Analysis	Six section buttons, each a shared <code><Section></code> (R17); selecting one closes the previously open one (accordion); open button flips to accent-bg/inverse-text; View All opens all six.	<i>Collapsed</i> default; <i>one open</i> ; <i>all open</i> .
Empty / first load	A bundled sample is loaded so the deck is never blank, with an explicit in-content "this is sample data" callout (A5).	<i>Sample</i> on first paint; replaced on user upload.
Global error	Parse failure → "No schemes found. Is it a CAMS / KFinTech consolidated statement?"; an unanticipated render error is caught by an error boundary (R11) showing "Something went wrong — your data never left your device" with working recovery controls.	Non-destructive; the previous view is retained where possible; a fresh upload/refresh clears a tripped error boundary automatically.

6.4 Design Tokens — dual theme, both WCAG AA

Every color routes through CSS custom properties (`ui/tokens.css`) — no hardcoded hex anywhere in component CSS — so both themes and the instant toggle between them apply without touching component styles.

"Terminal Deck" (dark, default) — JetBrains Mono throughout
 paper #0a0b0d · ink #edeff2 · card #1ald22 · card-hover #262a31 · line #333842
 accent/green #e8a33d · brass #c98a2e · teal #5eead4 · clay #d97757 · muted #8a8f99
 pos #5eead4 · neg #ff6b5e · frame #101216

"The Ledger" (light) — Fraunces (serif headings) + Courier Prime (body/mono)
 paper #fbf3e7 · ink #2b2118 · card #f5ecdc · card-hover #ecdcc0 · line #d9c7a3
 accent/green #2f5233 · brass #846639 · teal #3b5563 · clay #8b2e2e · muted #74654e
 pos #2f5233 · neg #8b2e2e · frame #f2e7d0
 (contrast-pass corrected 2026-07-12, review item B1 — muted/brass previously
 measured 3.78:1 / 2.59:1 against paper, both below WCAG AA's 4.5:1; now 5.14:1 /
 4.84:1)

allocation (both themes, hue-shifted to stay on-brand): equity · debt · cash · other
 — see --cat-equity/--cat-debt/--cat-cash/--cat-other per theme in tokens.css
 type: tabular-nums on all figures; hover-lift on interactive cards uses a
 cubic-bezier(.34,1.56,.64,1) overshoot easing (replacing framer-motion, R12),
 fully disabled (not just sped up) under prefers-reduced-motion
 breakpoints: 640 (mobile) · 860 (narrow — type/padding) · 1023 (tablet — grid
 collapse + corner-button relocation, unified in review item D2)

7. Release Plan, Milestones & Risk Management

7.1 Phased Implementation Timeline

Original build (Phases 1–9) — all complete.

Phase	Scope	Status
Phase 1 — Foundation	Vite/React/TS scaffold, tokens, golden-fixture CI harness	✅ Complete
Phase 2 — Ingestion & Parser	pdf.js + MarkItDown + paste routes; CAMS/KFintech parser; parity + golden tests	✅ Complete
Phase 3 — Engine	XIRR (all-time + 1Y), CAGR, Modified-Dietz, STCG/LTCG, allocation, series	✅ Complete
Phase 4 — Core UI (Command Deck)	Masthead, KPI rail, 2-column deck, 6-chart gallery, sortable tables, allocation drill-down	✅ Complete
Phase 5 — Commentary & Benchmark	Age/retirement-age commentary; Nifty 50 index-fund-proxy comparison	✅ Complete
Phase 6 — Data Check & Hardening	Reconciliation panel; provenance; exited-folio handling	✅ Complete
Phase 7 — Market-data reliability	Cached AMFI edge function (primary) + rewire resolve (fallback)	✅ Complete (N2–N3)
Phase 8 — Public-product bar	Accessibility (A), Security/CSP/egress test (S), Playwright e2e (T)	✅ Complete

Phase	Scope	Status
Phase 9 — Deploy & Launch	Static SPA + edge-fn deploy config; in-app privacy note	✅ Complete (D1–D2; account/push steps are the operator's)

2026-07-12 comprehensive review — "empower, not just display" — all five themes complete, tracked in `tasks.md` as R1–R23:

Theme	Scope	Status
A — Product empowerment	InfoTips (A1), actionable insight flags (A2), retirement corpus projection (A3), Insight card promotion (A4), first-run clarity (A5), plain-language Data Check copy (A6)	✅ 6/7 (A7 — SIP/overlap/tax-loss features — deferred, each a separate feature-planning exercise)
B — Accessibility & inclusive UX	Light-theme contrast fix (B1), <code>aria-live</code> regions (B2), modal focus trap (B3), sortable-header semantics (B4)	✅ 4/5 (B5 — touch support for chart tooltips — deferred, bundled with a future mobile-optimization pass)
C — Architecture, leanness, testability	Error boundary (R11/C4), drop framer-motion (R12/C5), shared feedback validation (R13/C7), type-safety batch (R14/C3), shared <code>InteractiveChartFrame</code> (R15/C2), retire last <code>dangerouslySetInnerHTML</code> sink (R16/C6), decompose <code>App.tsx</code> (R17/C1)	✅ 7/7
D — CSS & design-system coherence	Dead-CSS cleanup + <code>.dc-main</code> / <code>.privacy-footnote</code> fixes (R18/D1), breakpoint consolidation closing a real 781–1023px layout seam (R19/D2), app.css/deck.css layering fix (R20/D3)	✅ 3/3
E — Repo & data hygiene	Root cleanup — dead binary removed, stale docs refreshed, hand-duplicated table deduplicated, manual-test fixtures relocated (R21/E1); <code>FUND_META</code> staleness canary + <code>geo.ts</code> tests (R22/E2); PWA manifest (R23/E3)	✅ 3/3

Post-review polish (ongoing, ad hoc): user-reported UI feedback picked off as it arrives outside the formal review cadence — e.g. the upload drop zone's permanent (not hover-only) highlight, 2026-07-13.

Phase	Scope	Status
Phase 10 — Post-launch roadmap	Multi-statement merge; demat (NSDL/CDSL); CSV export; optional encrypted local save; SIP-pattern/overlap/tax-loss features (A7)	 Deferred

7.2 Risk Assessment Matrix

#	Risk	Prob.	Impact	Mitigation
R1	NAV endpoint failure or drift (hobby endpoints change/rate-limit; AMFI has no CORS).	Low (was Med)	High	Multi-source with plausibility gate + graceful statement-NAV fallback; primary is now the built, cached AMFI edge function (N2–N3), reducing dependence on per-ISIN hobby hits — verified live with all live sources unreachable, the dashboard still renders correctly on statement NAV.
R2	Silently stale/wrong benchmark or NAV (a wound-up scheme keeps its last value; a wrong-fund name match).	Med	High	Benchmark staleness recency check + longest-history preference; NAV $\frac{1}{3} \times - 3 \times$ plausibility gate ; blank-rather-than-guess; live browser verification, not just green tests.
R3	Parser breakage on an unseen CAS layout (new CAMS/KFintech variant).	Med	Med	Position-independent, pattern-based parsing; source-agnostic normaliser; golden-fixtured CI across real CAMS + KFintech statements; add fixtures as new layouts appear.
R4	Privacy regression (an added feature accidentally transmits statement data or adds an analytics beacon).	Low	Critical	Hard architectural boundary (only <code>marketdata/</code> egresses, prices only); built, automated no-PII-egress test (S3, <code>egress.spec.ts</code>); strict CSP (S1, built); explicit guardrails (§8).
R5	XSS via crafted fund name.	Very Low (was Low)	High	Fully mitigated , not just tested-around: zero <code>dangerouslySetInnerHTML</code> sinks remain anywhere in <code>app/src</code> (R16 retired the last one, Commentary) — React's own JSX text-escaping does the job structurally now, not by discipline.
R6	Correctness regression (a refactor moves a golden total or breaks the plausibility gate).	Low	High	Rupee-exact golden fixtures + decoy regression tests block merges; documented invariants in <code>docs/DECISIONS.md</code> . A real, if latent, instance was caught mid-refactor during R14: three files independently duplicated a "is this holding still open" check, and two had silently diverged — found by consolidating into one shared helper, not by a pre-existing test (no current fixture happened to exercise the disagreement).
R7	Layout seam at an unusual viewport width (a design-system coherence risk found by the 2026-07-12 review, not previously listed here).	Low (newly mitigated)	Med	Found: five uncoordinated CSS breakpoints (639/640/780/860/1023) left a real 781–1023px range where fixed-position corner controls could float over an already-collapsed layout. Fixed by consolidating to a documented 3-tier contract (R19/D2); verified programmatically at both former boundary widths, not just spot-checked.

#	Risk	Prob.	Impact	Mitigation
R8	Hand-curated reference data (<code>FUND_META</code> , <code>name-alias tables</code>) silently going stale as new funds/renames appear.	Low (newly mitigated)	Low–Med	A staleness canary (R22/E2, <code>fundMetaCoverage.spec.ts</code>) makes the exact fallback-to-inference rate per real fixture an explicit, checked number, so future drift is a visible failing test rather than an invisible quality regression.

8. Guardrails — What This Product Must NOT Do

These are **hard constraints**. A change that violates any of them is a defect, regardless of feature value.

Privacy & data handling

1. **Never transmit the statement, the PDF, PAN, folio numbers, holdings, or amounts off the device.** Outbound requests may carry **only** a scheme name or ISIN for a public NAV lookup.
2. **Never add third-party analytics, ad, session-replay, or error-tracking scripts** to any route that has touched statement data. Zero beacons.
3. **Never persist user financial data server-side.** No accounts, no cloud sync, no server DB in v1.0. Any future local persistence must be opt-in, encrypted (WebCrypto/AES-256-GCM), and off by default.
4. **Never route statement data through a public CORS proxy.** (These were deliberately removed as a production liability; do not reintroduce them.)

Correctness & honesty

5. **Never present a guessed, stale, or implausible figure as if it were current or real.** If a NAV fails the plausibility gate or a benchmark fund is stale/unmatched, fall back with a stated reason or leave it **blank** — do not fabricate.
6. **Never break the golden-fixture rupee-exact totals** or the wrong-fund-decoy rejection without an explicit, reviewed decision.
7. **Never claim to bundle or "attach" copyrighted material** (e.g., books). Reference by citation only; use only publicly/freely available factual data.

Scope & architecture discipline

8. **Never re-introduce a second implementation of the engine.** `app/` is the single source of truth; no HTML prototype, no mirror.
9. **Do not build speculative generality now** — no CSV/equity/demat ingestion, no multi-market abstraction, no Web Worker, no offline service-worker caching — until there is a concrete, decided need. Keep only the *documented seam*. (The **manifest-only installability shim** — F14, review item E3 — is explicitly *not* a violation of this: it adds no service worker and no offline caching, only "Add to Home Screen" metadata.)
10. **Do not expand `FUND_META` into a large maintained database.** It is a core-view input, not a data product; unknown funds fall back to inference.

Advice boundary & UX

11. **Never present the commentary as personalised financial advice.** Keep the educational framing and the SEBI-RIA disclaimer; never recommend buying/selling a specific security.
12. **Never block the initial render on the network.** Statement-only analysis paints first; live NAV and benchmark upgrade asynchronously.
13. **No dark patterns** — no forced sign-up, no retention hooks, no monetisation of financial data.

9. Glossary

Term	Meaning
CAS	Consolidated Account Statement (CAMS + Kfintech mutual-fund holdings for an email/PAN).
CAMS / Kfintech	The two registrar-transfer agents whose statement layouts the parser supports.
NAV	Net Asset Value — a fund's per-unit price.
AMFI <code>NAVA11.txt</code>	Official daily NAV file (no CORS → needs a proxy/snapshot/edge function).
XIRR	Money-weighted return over dated cash flows (the true "since inception" return).
CAGR	Compound annual growth rate.
Modified Dietz	Period return that accounts for the timing of cash flows.
TWR	Time-weighted return (contributions removed); used internally for the drawdown index.
STCG / LTCG	Short-/Long-Term Capital Gains (threshold: 12 months equity, 24 months debt).
Plausibility gate	Rejects a live NAV outside $\frac{1}{3} \times - 3 \times$ of the statement NAV (a wrong-fund match).
Glide path	Planned de-risking (equity → bonds) as retirement approaches.
Look-through allocation	Equity/Debt/Cash/Other split derived from each fund's underlying mix.
MarkItDown	Microsoft's PDF→Markdown converter; an optional, local, cleaner extraction route.
InfoTip	The small ⓘ point-of-use explainer attached to jargon-dense labels app-wide (F9).
Worth a Look	The short, data-derived list of specific things worth the user's attention — high expense, benchmark underperformance, concentration (F10) — rendered only when a real threshold is crossed.
Command Deck	The default, lean-core dashboard view (KPI rail + chart/holdings + allocation) that answers "how am I doing?" at a glance.
Terminal Deck / The Ledger	The app's dark and light themes, respectively — instant-toggle, both independently WCAG AA.

Term	Meaning
Error boundary	The React component wrapping the dashboard content that catches an otherwise-fatal render error and shows a recoverable fallback instead of a blank page.
Patch reducer	The <code>useReducer</code> pattern (<code>AppState.ts</code>) generalizing React's <code>setState(prev => ...)</code> escape hatch to a whole multi-field state atomic update at once.
Staleness canary	A test asserting an exact, currently-baselined number (e.g. the <code>FUND_META</code> fallback-to-inference count per fixture) so future drift in hand-curated data becomes a visible failing test instead of invisible decay.

This document describes the product as built as of 2026-07-13 (v1.1.0) — the original v1.0.0 build (2026-07-04) plus the 2026-07-03 architecture review's C/N/U/A/S/T/D workstreams and the 2026-07-12 comprehensive review's Theme A–E follow-ups (R1–R23), all landed — together with its committed quality bar and the small set of items still deliberately deferred. For live task status see `tasks.md`; for the original blueprint and architectural rationale see `plan.md` and `docs/`.